Unit 3- Q1 - Explain different types of cyber security testing

NOTE:

Cyber security testing - must include, but is not limited to:

• penetration • vulnerability • social engineering.

Vulnerability scanning: uses automated tools to detect known vulnerability in systems. Regular scans help address weaknesses. The scanner checks for issues such as outdated software, missing security patches, weak configurations, and known vulnerability. Regular vulnerability scans can help an organization identify weaknesses early, so they can be fixed before they are exploited.
Security scanning: identifies network or systems weaknesses and suggests mitigation strategies.
It includes checking network devices, systems, applications configuration, and security controls. The results can help companies decide what security improvements are needed.
Pen Testing: simulates real world attacks to uncover exploitable vulnerability and gives insight into how attackers might attack the system or network.
This shows whether vulnerability can actually be exploited and what attackers could access. This method provides info about the effectiveness of its security controls and helps identify vulnerability that needs to be fixed.
Socal Engineering Testing: Simulates phishing or manipulation tactics to test employee awareness and resilience against human targeted attacks. Other tests may simulate manipulations or impersonation techniques. These tests allow a company to test the security awareness of employees.

Penetration: focuses on attempting to gain unauthorized access to system or information by exploiting identifies weaknesses. Unlike vulnerability, penetration testing attempts to demonstrate whether that vulnerability can actually be exploited.

Unit 3- Q2 - Identify why cyber security testing is important

Cybersecurity testing helps companies identify and fix vulnerability in systems applications and networks before malicious actors can exploit them. It safeguards information, intellectual property, and critical infrastructure from threats such as unauthorized access to data breach, malware injections, and cross site scripting.

By evaluating security controls against real world attacks scenarios, companies can assess risk and priorities threats effectively. Techniques like simulated scenarios which provide insight into which vulnerability poses the greatest risk.

Trust & reputation: a strong cybersecurity practice, validates though testing, enhances clint trusts credibility. Companies that fail to test adequately risk reputational damage, loss of customers, and diminished customer confides.

Constant improvement: testing creates a culture of responsibility and continuous improvement within development and operations teams.

Adapting threats: as digital adoptions grow, threats grow and become more sophisticated. Continuous security testing allows companies to stay ahead of emerging threats, adapt defenses, and maintain resilience.

Unit 3- Q3 - Compare types of cyber security testing

Testing Type	Focus	Main point
Vulnerability	Technical weakness	Finds knows Vulnerability
Security scanning	Systems, Network, and configurations	Identify weaknesses and possible mitigation
Pen Testing	Technical Security	Attemps to exploit Vulnerability
Socal Engineering Testing	People	Test awareness and resistance to manipulation

Unit 3- Q4 - Consider mitigations following cyber security testing

NOTE:

Mitigations must include, but are not limited to:

• escalation

• patching (including software updates, operating system updates, application updates)

• user access control • high availability • staff training and awareness.

Mitigations

After cyber security testing has identified vulnerabilities or weaknesses, a company should take the appropriate mitigations measures to reduce risk.

Escalation

If a vulnerability is serious or cannot be fixed by the person who identified it, it should be escalated to a more experienced member of the IT or cybersecurity team.

Patching and software updates

Companies should install security and updates to fix vulnerability. This includes software, operating systems updates, and applications updates.

User account control

Access controls should be used to ensure that users only have access to the system and information they need to do their job. Unnecessary accounts and perditions should be removed, and stronger authentication methods such as multy- factor can be introduced where appropriate.

High availability

Measures help keep important systems and services operational even if a system fails or is affected by a cyber-attack. This can include backups, redundant systems, and alternative network connections.

Staff training and awareness.

Employees should receive regular cybersecurity training so they can recognize and respond appropriately to threats such as phishing, social engineering, and suspicious attachments.

Unit 3- Q5 - Explain why it is important to retest following any changes made

It's important to retest systems following any changes because the company needs to confirm that the changes have successfully fixed the identified security vulnerability or weakness. For example, if a vulnerability scan identifies an app using outdated software, the company may install the latest version. The system should then be tested again to confirm that the vulnerability has been resolved. Retesting can also identify whether the changes have introduced new vulnerability. A change to a system configuration could accidentally weaken another security control or cause an existing security feature to stop working correctly by retesting it allows security professionals to confirm that systems and apps are still functioning correctly after the changes have been made.

Unit 3- Q6 - Explain **how** the outcomes of cyber security testing can be reported

Summary: Provides a non-technical overview of the test objective, scope, and overall security posture. It highlights critical findings and recommendations in plain language for executives.

Key findings: Summarize the most critical vulnerabilities with their potential impact and prioritization based on severity.

This helps executives focus on the most critical issues.

Engagement summary: Details the scope, timeline, and target of the test including systems, apps and networks.

Test Results and Vulnerabilities Details: lists of all identified vulnerabilities, technical description, with evidence like screenshots, logs, network traffic.

Redamations Recommendations: Provides actionable steps to address all vulnerabilities found prioritizing action based on risk and potential impact.

Testing Methodology: Outlines tools and techniques and processes used during the test.

Unit 3- Q7 - Explain **why** the outcomes of cyber security testing **must** be reported

Clear Identification of vulnerabilities: It confirms weakness affected components and exploitation evidence allowing engineering teams to understand what to fix.

Supports Effective Remediation: reports provides reproducible steps and prioritize recommendations. This helps teams focus on high impact issues.

Enables Leadership & Risk Management: Executives & business owners need reports to understand risks/ exposure to make the best decision they can, which also allows executives & businesses to allocate resources and track security improvements.

Unit 3- Q8 - Identify cyber security vulnerabilities

NOTE:

You should identify a range of cyber security vulnerabilities, taking into account cloud-based and on premises. You should also include common vulnerabilities in networks and systems.
Cyber security vulnerabilities: a cyber security vulnerability is a weakness or flaw in a system, network, application, device or process that could be exploited by a threat actor.

Common network vulnerabilities:

Weak passwords- weak reused easily gassed passwords can allow attackers to gain access to user accounts and network resources.

Misconfigured firewalls: Incorrect firewalls may allow unnecessary network traffic or service to be accessed, creating opportunities for attackers.

Unsecured network devices: router, switches, and other network devices may contain vulnerabilities if they use default passwords for outdated firmware or insecure configuration.

Common system vulnerabilities:

Outdate software: Operating system and application that are not updated may contain security vulnerabilities

Malware: Systems can be vulnerable to malicious software such as viruses, ransomware, spyware, and trojans.

Poor access controls: giving users permission than they require can create a compromised account to access sensitive data.

Incorrect configuration set up: can lead to a system exposed. For example, unnecessary service may be enabled, or security controls may be disabled.

Cloud base vulnerabilities:

Misconfigured cloud storage: may accidentally be configured to allow unauthorized users to access sensitive data.

Weak cloud controls: giving users permission that they don’t need.

Compromised cloud accounts: if an attacker obtains a user's cloud info, they may be able to access cloud files.

Unit 3- Q9 - Demonstrate the steps to be taken when a vulnerability has been identified

NOTE:

You must demonstrate the steps to be taken when a vulnerability has been identified. Whilst the steps will vary, you must include reference to organisational policies/procedures within the steps.

When a security vulnerability is identified, a company should follow its established security policies and procedures.

Identify and record the vulnerability: The first step is to confirm what vulnerability is and record the relevant info. This could include the affected system device application or network how the vulnerability was discovered and any evidence from the security testing.

Assess the risk and severity: The organization should assess how serious the vulnerability is. This should consider factors such as the likelihood of the vulnerability being exploited and the potential impact on system data and user. For example, a vulnerability that could allow an attacker to access sensitive information would need to be treated as a higher priority than a vulnerability with lower impact.

Assess the risk and severity: the company should assess how serious the vulnerability is. Consider factors such as the likelihood of vulnerability being exploited and the potential impact on system data and users. For example, a vulnerability that could allow an attacker to access sensitive info would need to be treated as a higher priority than a vulnerability with low impact potential.

Follow organisation policies and procedures: the person who identifies a vulnerability should follow its company established security policies and procedures. They shouldn't make unauthorized changes to the system.

Escalate the vulnerability if necessary: if the vulnerability is serious, the issue should be escalated to the appropriate IT/ Cybersecurity management team. If the person who discovered the vulnerability does not have the authority or technical knowledge to fix it, they should escalate it rather than attempting an unauthorized solution.

Apply an appropriate mitigation includes

- Installing a software or operating system security patch.
- Updating an application.
- Change firewall or network configurations.
- Removing unnecessary service.
- Changing user permissions.
- Enabling stronger authentication.
- Replacing unsupported software or hardware.
- Providing additional staff security training.

Unit 3- Q10 - Apply the correct response to the vulnerability

NOTE:

An example of a correct response could include patching or carrying out an update.
Apply the correct response to a vulnerability to a weak password-> If a cyber security testing identifies that users are useing weak or easily gassed password, the company should respond by improving its password security controls.

First, the vulnerability should be recorded and assessed according to the company's vulnerability management procedure. If the weak password created a significant risk, the issue should be escalated to the appropriate IT or cybersecurity team.

The company can require affected users to change their password and introduce a stronger password policy. The policy could require password to be sufficiently long and prevent users from using commonly used or previously compromised passwords.

Where possible, the organization should also enable melty factor authentication. This provides an addition layer of security because an attacker would need more than just the user password to access the accounts.

The IT team should then check that the new password requirements and access controls have been correctly applied. Any affected accounts should be monitored for suspicious log activity.

Finaly the company should reset the vulnerability to confirm that weak passwords can no longer be used and that the security controls are working correctly.

Process: Identify -> Record and assess the risk -> Escalate is required -> Require stronger password -> Enable MFA where apricate -> Test new controls -> monitor accounts -> Retest -> Record the outcome.

Unit 3- Q11 - **Develop** an appropriate communication to mitigate future vulnerabilities

NOTE:

Communication documents could include an information leaflet or an email to management informing them of a vulnerability.

Protect your password

Recent cyber security testing has identified that weak passwords can create a security vulnerability.

Weak or easy gassed passwords can make it easier for attacks to gain unauthorized access to user accounts and potentially access company info.

All staff have a responsibility to help protect the organization's systems and info.

How to create a strong password:

- Use a long password that is difficult to guess.
- Avoid using personal info such as your name, birthday or address
- Do not reuse your work password for personal accounts
- Do not use common passwords like Password 123
- Never shire your password with another person
- Do not write passwords where other people can easily see them
- Use an approved passwords manager if one is provided by the company.

Use multi factor authentication

Where available, use MFA for additional layers of protection for your accounts. MFA means that passwords alone won't be enough to access an account, helping to reduce the risk is a password is compromised.

What to do if you think your password is compromised.

If you believe someone else knows your password reports, it to the appropriate IT or security team immediately and follow the company's security procedures.

Remember: strong passwords & MFA helps protect you, your colleagues and the organization from unauthorized access.

Unit 3- Q12 - **Identify** cyber security controls

Cyber security controls are a security protocol by companies to protect their systems, networks, and data from cyber security threats. These controls help prevent attacks, detect suspicious activity, and reduce the impact of cyber security incidents.

Access controls: restrict access to system and information so that only authorized users can access them. For example, users' accounts can be given different permissions depending on their job roles.

Firewalls: monitor and control incoming and outgoing network traffic based on predefined security rules. They help prevent unauthorized access to a company's network.

Antivirus and anti-malware software: both detect and block and remove malicious software such as viruses, ransomware, and spyware.

MFA requires users to provide two or more forms of vesications when logging in. This adds an extra layer of security if a password is stolen or compromised.

Encryption: converts info into an unreadable format that can only be accessed using the appropriate decryption key. Helps protect sensitive info from unauthorized access.

Security Patching and updates: software updates fix known vulnerabilities in operating system, application and device. Regular updates help prevent attackers from exploiting outdated software.

Intrusion Detection and Prevention Systems: monitor network or systems activity for suspicious behavior and alert security teams to possible attacks.

Unit 3- Q13 - **Explain** a basic cyber security framework

NOTE:

You must explain a basic cyber security framework. An example could be:

• National Cyber Security Centre (NCSC), 10 Steps to Cyber Security

• Centre for Internet Security (CIS) controls.

The National Cyber Security Center (NCSC) 10 Step to Cyber Security:

- **Risk Management:** Identifies and assesses cybersecurity risk so a company can priorities threats and decide how to reduce them.
- **Engagement and Training** educates employees about cybersecurity threats and encourages secure working practices to reduce human error.
- **Asset Management:** Identify and keep track of the organization's devices, software, system, and data so that everything important can be protected.
- **Architecture and configuration:** systems, networks are designed, configured and maintained securely to reduce vulnerabilities.
- **Vulnerabilities Management:** Identify and manage security weaknesses by carrying out security testing, applying patches, and keeping systems updated.
- **Identity and access management:** controls who can access what information they have premotions to access. This includes using strong authentications and gives users only the permission they need.
- **Data Security**: Protects sensitive info from unauthorized access.
- **Logging and Monitoring:** activities across systems and networks to help detect suspicious behavior and investigation of incidents.
- **Incident Management**: Establishes procedures for responding to cybersecurity incidents reducing there impact and restoring normal operations.

- **Supply Chain Security:** ensures that suppliers and external service prodders meet appropriate security standers.

Unit 3- Q14 - **Evaluate** a cybersecurity framework

NOTE:

Example of an evaluation – *an organisation may not encrypt the network traffic as if they encrypt it, they can't read what is coming in via the network. What are the advantages and disadvantages of this?* **(This is an example and not part of the question)**
A cybersecurity framework can be useful because it gives an organization a structured way of managing cybersecurity risks and deciding which controls should be used. However, a company should not automate applying every part of a framework because different companies have different needs, risks, budgets, and working practices.

For example, encryption can protect sensitive data by making it difficult for unauthorized people to understand the data. This can be especially useful when protecting confidential records or clint info. However, encrypting network traffic can also make it more difficult for a company to inspect and monitor what is going on.

Another example is a firewall. A firewall can help protect companies by blocking unwanted or dangerous network traffic. However, if it's configured incorrectly or too strictly, it could block websites, applications or information that employees use/ need to carry out their work. This will reduce productivity and potently cause problems

When evaluating a cybersecurity framework, a company should therefore consider its impact and business needs and priorities, long-term plans, security risks, budget, and overall approach. Frameworks such as CIS & NCSC can provide a good starting point for their company. Whereas NIST can be useful for developing a more mature cybersecurity program.

Unit 3- Q15 - **Explain** how to apply controls

NOTE: You must explain how to apply a minimum of four cyber security controls; you will have identified these in question 12.

Access controls- are enabled for companies, so people don't have access above their rank or job title should permit. For example, an employee should only have access that allows them to do their job and shouldn't have the perms to edit or delete flies. User perms should be reviewed regularly and changed when a person's job roles change.

Encryption - converts info into an unreadable format that can only be accessed using the appropriate decryption key. for example, a company can encrypt important or stored data on devices.

Antivirus and anti-malware software- can be applied by installing approved security software onto computers and other devices. The software can monitor the device for malicious software or programs help detect or remove malware. It should be kept up-to-date.

MFA- requires users to provide two or more forms of vesications when logging in. This adds an extra layer of security if a password is stolen or compromised. For example, may enter their password and then must enter another verification method

Unit 3- Q16 - **Implement** a basic cyber security control

NOTE:

You must implement a basic cyber security control; an example of this could be demonstrating how to give access/deny access to a folder or drive.
Implementing folder access permissions: A basic cybersecurity control that can be implemented is access control using NTFS permissions. This controls which users are allowed to access a folder and what they are allowed to do with the files inside it.
Steps to implement the control:

- Create a test folder on windows computer, for examples Cyber–Security Test.
- Right-click the folder and select Properties.
- Select the security tab.
- Select Edit to change the permissions.
- Select the user or group that needs access to the folder.
- Give the user the appropriate permissions, such as Read, Write, or Modify, depending on what they need to do.
- If a user should not have access, their permissions can be removed, or access can be denied.
- Select Apply and then OK to save the changes.
- Test the control by logging in as the relevant user and checking whether they can access, modify or create files in the folder.

Result
The folder now has access to permissions applied to it. Users can only perform the actions that their permissions allow. This helps reduce the risk of unauthorized access, changing, or deleting important information.
The permission should also be reviewed regularly to make sure users still have the correct level of access for their job role.

Unit 3- Q17 - **Justify** the implementation of the chosen cyber security control
Justification for implementing folder access permissions: I chose to implement NTFS folder access permissions because they help protect information from unauthorized access. By giving users only permission they need for their job, the organization can reduce the risk of employees accessing, changing or deleting information that they do not need.
This control is partially useful for protecting sensitive or important company information. For example, an employee may only need permission to read documents while another employee may need permission to modify them. Giving each user the appropriate level of access follows the principle of last privilege.

Unit 3- Q18 -**Explain** why a control might not be applied

NOTE:You must explain reasons why a control might not be applied, for example, when is doing nothing a better option?

A cybersecurity control might not apply if it is not suitable for the organization's needs or if the disadvantages are greater than the benefits.
One reason is the cost. Some controls can be expensive to purchase, install, and maintain. If a company has a limited budget, it may be better to spend the available money protecting systems that have a higher level of risk rather than trying to protect every possible risk.

Another reason is that control could interfere with normal business actives. For example, a firewall may block websites or information that employees need to carry out their jobs. In this situation, applying control without considering its impact could reduce productivity.

Control may also not be necessary if the risk is very low or does not apply to the company. For example, if employees never work remotely and their devices are not exposed to unsecured public WIFI, there may be little benefit in using a control specifically designed to protect against unsecured WIFI.

Good to know.
HOW outcomes of cyber security testing can be reported:
1. Detailed report to senior management

- **The most common method**
- **Used for full tests**

2. Shorter formats for small, regular tests

- **Memo**
- **Incident log**
- **Short report**
- **Example: scheduled malware scans**

3. Direct report to the software developer

- **Used by white hat hackers who find software bugs or zero-day issues**
- **Often done through the developer's online form or set procedure**

What a thorough report should include

- **Executive summary: a brief overview of the major findings**
- **Raw data: output from the tools used in the test**
- **Comprehensive list of findings: everything that was discovered**
- **Proposed solutions: the steps needed for remediation**

Who may read it

- **Senior management**
- **IT teams**
- **Clients**
- **Regulators**

So it must be clear, logical, and set out the problems and recommended solutions. Writing the report is one of the most critical tasks of a security tester or ethical hacker.



How legislation impacts on cyber security

GDPR

Data protection Act

Computer Misuse Act

Online Safety Act